



The Problem

AI systems can leak data, take unsafe actions, or break compliance expectations — often through predictable failures like prompt injection, insecure output handling, or weak supply-chain controls. OWASP’s GenAI security guidance and NIST’s GenAI profile both highlight the importance of testing and controls for these realities.

SMBs usually don’t need a 12-month governance program to start. They need clear risks, practical fixes, and repeatable guardrails that match their people and budget — while still mapping to recognized standards for customers in the US, LATAM, and the EU. The AI RMF was explicitly designed to be flexible and usable by organizations of all sizes.

Why agitru

Right-Sized Assessments	Built for SMB AI Reality	Audit-Ready Evidence
Fixed-scope packages with clear deliverables and timelines — built on OWASP GenAI guidance and NIST AI RMF functions. No enterprise overhead.	Your stack is vendors, SaaS copilots, and open-weight models. We test the way you actually use AI — including third-party resources and value chain risks.	Lightweight, audit-friendly artifacts: system documentation, evidence plans, and reusable test suites. EU AI Act allows SMEs simplified documentation.

Standards Alignment

Standard	Focus
NIST AI RMF	Risk management framework — GOVERN, MAP, MEASURE, MANAGE
NIST GenAI Profile	Generative AI-specific risk guidance and red teaming
ISO/IEC 42001	AI management system standard
OWASP GenAI Security	LLM Top 10 & Agentic AI Top 10
EU AI Act	European regulatory framework for AI systems

Services

Our services are packaged so SMBs can pick what they need now and add maturity over time. We use the AI RMF as the organizing spine — because it is designed to be resource-efficient, voluntary, and adaptable by context.

01 AI Security QuickScan for LLM Apps & Agents

1–2 weeks · Fixed scope

Best for SMBs piloting or already using GenAI — chatbots, RAG search, customer support automation, agentic workflows. Baseline: OWASP Top 10 for LLMs & Agentic AI + AI RMF MAP/MEASURE outcomes.

- Architecture and dataflow review
- OWASP-aligned test summary with prioritized fixes
- Release Gate Checklist for production readiness
- One-page executive readout with 30-day recommendations

02 LLM & Agent Red Team Sprint

3–5 weeks · Fixed scope

Best for SMBs with real production usage, customer-facing AI, or AI connected to tools like email, CRM, ticketing, code, and workflows. Aligned to OWASP's Top 10 for Agentic AI and the NIST GenAI red teaming guidance.

- Threat model + abuse-case catalog tailored to your agent/tool permissions
- Adversarial test suite with reproducible prompts and regression set
- Findings report with exploit narratives and engineering-ready mitigations
- Retest validation confirming risk reduction

03 Open-Weight Model Intake Gate

2–3 weeks · Fixed scope

Best for SMBs downloading models from public hubs, fine-tuning, or embedding open models in products. Unsafe model artifacts can enable arbitrary code execution — intake controls matter.

- Model intake checklist and risk rating (approve / containment / reject)
- Artifact review with safe-loading control recommendations
- Sandbox execution plan for safe pre-production testing
- Supply-chain bill of materials for AI components

04 Responsible AI Starter Kit for SMBs

4–6 weeks · Fixed scope

Best for SMBs that need governance without bureaucracy — especially when customers ask “how do you manage AI risk?” Anchored in AI RMF GOVERN outcomes.

- AI use-case inventory + basic risk tiering
- Lightweight governance charter (decision rights, approvals, escalation)
- SMB-friendly AI policies and baselines
- Current vs. Target AI RMF profile with 90-day action plan

05 ISO 42001 & EU AI Act Readiness Accelerator

6–10 weeks · Fixed scope

Best for SMBs selling into the EU, working with enterprise customers, or preparing for procurement/audit requirements. ISO 42001 + EU AI Act documentation, logging, and cybersecurity controls.

- ISO 42001 readiness snapshot + roadmap
- EU AI Act applicability and timeline briefing
- EU AI Act evidence starter pack (Articles 11–12–15)
- SME-friendly documentation approach

06 Continuous AI Evals & AI SecOps Light

Monthly · Retainer

Best for SMBs that want ongoing protection after go-live without building a dedicated AI security team. The AI RMF emphasizes risk management as continuous across the lifecycle.

- Monthly eval runs: security regressions, safety regressions, abuse scenarios
- CI/CD gates and stop/ship criteria for prompts, tools, and model updates
- Logging + evidence hygiene support
- Quarterly executive risk review

07 Virtual CAIO & AI Steering Committee Support

Ongoing · Advisory

Best for SMBs that need senior AI leadership without a full-time hire. A fractional Chief AI Officer embedded in your governance structure — bringing NIST AI RMF expertise, vendor oversight, and strategic direction.

- AI steering committee participation with defined governance cadence
- AI roadmap co-ownership, vendor/model evaluation, and use-case prioritization
- Board-ready AI risk briefings and regulatory change monitoring
- AI literacy workshops for leadership and team capability assessments

How It Works

A quick-start engagement flow designed for SMBs who need to move fast without cutting corners.

Step	Action	Detail
1	30-Minute Scoping Call	We map your AI use cases, where sensitive data lives, and whether tools or agents can take actions. Free, no pressure.
2	Fixed-Scope Proposal	Clear package, timeline, deliverables, and access requirements. Within 2 business days.
3	Execute & Handoff	Actionable artifacts — test suite, roadmap, evidence starter pack — and a short leadership readout.

Frequently Asked Questions

Do you guarantee that our AI will be “safe” or “compliant”?

No. AI risk cannot be reduced to zero, and the NIST AI RMF frames risk management as continuous. We provide risk reduction, evidence, and practical controls — but not a guarantee of outcomes.

Do you provide legal advice for the EU AI Act?

No. We provide technical, operational, and evidence implementation support. Legal interpretation should come from qualified counsel.

We’re outside the EU — does the EU AI Act still matter?

It can. The EU AI Act scope includes providers in third countries placing AI systems on the EU market, and deployers where AI output is used in the EU.

What’s the fastest way to start?

Most SMBs start with the AI Security QuickScan (1–2 weeks) to identify highest-impact risks, then expand to a Red Team Sprint or governance kit as needed.

Will you test our agent tools (CRM, email, APIs)?

Yes. Agent and tool testing is a core focus because insecure output handling and prompt injection can trigger downstream actions if tool permissions are not controlled.

How do you handle our data and customer records?

We default to working inside your environment. If access is needed, we apply minimization, retention limits, and secure deletion aligned to your needs.

What’s required from our team?

Usually: a technical sponsor, read-only access to relevant repos/environments, and short interviews with engineering, product, and security. We keep the burden on our side.

What happens after the assessment?

We can deliver a remediation sprint and/or provide a monthly AI SecOps Light retainer to keep protections current as models and tools change.

Get Started

Schedule a free 30-minute scoping call with a principal consultant. We'll map your AI risk landscape and recommend the right starting point.

Email	WhatsApp	Regions
contact@agitru.com	Available	US · LATAM · EU

Sister Company: Need responsible AI systems built from scratch? Meet **aibeja** (aibeja.com) — secure AI design, development, and operations.

agitru provides technical, security, and operational risk management services. We do not provide legal advice. Regulatory applicability and interpretation (including EU AI Act scopes and obligations) should be confirmed with qualified legal counsel. Pricing, SLAs, and timelines are illustrative until confirmed in a signed statement of work.

© 2026 agitru